

Verifiable Evidence for Human-Oversight Events

A proposed minimum interoperable event profile for prEN 18229-1 (Logging) and prEN 18229-3 (Human oversight), with fail-closed conformance tests.

Author: Iman Schrock, EMILIA Protocol Date: 17 July 2026 Status: informal technical contribution

1. THE STANDARDS QUESTION

A system can log that “human review occurred” without preserving evidence that a specific eligible person authorized, declined, amended, or rejected a specific consequential action before execution. Log integrity alone does not make the underlying authorization claim independently reproducible.

Proposed requirement: where a deployment relies on human authorization as an oversight measure, its evidence profile should let a non-participating assessor reproduce the authorization result from the retained artifact and fixed trust inputs, and should refuse when required evidence is missing, substituted, stale, or replayed.

2. MINIMUM EVENT MODEL

ELEMENT	MINIMUM SEMANTIC REQUIREMENT
Event and profile version	Unambiguous type and version; unknown critical semantics refuse.
Exact action commitment	Digest over canonical material fields, with action type and field registry/profile identified.
Typed human outcome	At least approved, declined, amended, and rejected. Only approval may authorize the original action; amendment/rejection point to a successor request.
Principal and trust reference	Signer identifier, key identifier, role, assurance profile, and relying-party-pinned trust input. An embedded key must not establish its own authority.
Eligibility and separation	Initiator identity, eligible approver set or authority reference, distinct-human/key requirements, and threshold where applicable.
Policy and presentation context	Policy/profile digest and, where claimed, a commitment to the material display. The record must not imply proof of perception.
Freshness and replay controls	Challenge nonce, issuance/expiry, revocation/status reference where required, and one-time consumption semantics at the executor.
Execution linkage	Executor record binds the observed material effect fields to the authorized action and names unknown/partial outcomes.

3. REQUIRED SEPARATION OF CLAIMS

The evidence profile should distinguish: **identity** (who a key represents), **authority** (what that principal may do), **policy** (what the deployment requires), **authorization** (what was approved), **execution** (what the executor attempted or observed), and **legal reliance** (what conclusion an assessor may draw). No artifact should establish its own trust root merely by naming one.

Conformance must attack the claim, not only parse the artifact.

4. MINIMUM NEGATIVE CONFORMANCE SUITE

01 Action substitution

Change one material action field after approval. Verification must refuse.

02 Unpinned or embedded key

A self-supplied valid signature must not establish identity or authority.

03 Role substitution

A policy decision, attribution record, or possession proof must not fill the human-authorization requirement.

04 Self-approval

Where separation of duties is required, the initiator cannot satisfy an approver seat.

05 Duplicate quorum member

One human or key must not fill multiple distinct seats.

06 Stale or revoked authority

Expired evidence or missing required current-status input must refuse.

07 Replay and concurrency

At most one presentation may reserve the protected effect, including concurrent delivery.

08 Policy mismatch

A valid signature under a different policy/profile must refuse.

09 Execution mismatch

Observed material execution fields that differ from the authorization must refuse or surface an unknown outcome.

10 Unavailable state

Required revocation, registry, consumption, or evidence-log state being unavailable must not create a permissive fallback.

5. EXPLICIT NON-INFERENCE REQUIREMENTS

A conforming artifact may establish that a pinned key signed an exact action under a stated context. It must not, without separate evidence, be represented as proof that: the key was correctly enrolled to a legal identity; the person understood the display or was free from coercion; the person was competent; the action was lawful, wise, safe, fair, or accurate; every relevant action traversed the enforcement point; or the complete oversight design satisfies Regulation (EU) 2024/1689.

6. WHY INCLUDE REPRODUCIBILITY

- **Interoperability:** a retained event remains meaningful after the original operator or vendor is unavailable.
- **Assurance:** positive and negative vectors make the claimed security property testable across implementations.
- **Portability:** the evidence can travel across provider, deployer, auditor, insurer, and market-surveillance boundaries.
- **Scope honesty:** the standard can require the artifact to expose assumptions and exclusions rather than imply them away.

7. IMPLEMENTABILITY EVIDENCE AND REQUESTED DISPOSITION

EMILIA Protocol provides an Apache-2.0 reference implementation, public conformance vectors, action-bound authorization receipts, WebAuthn signoff, M-of-N distinct-human verification, one-time consumption, execution-field binding, typed refusals, and formal models of named core properties. The protocol texts are active individual IETF Internet-Drafts, not adopted standards or endorsements. This contribution does not ask JTC 21 to select EMILIA.

Requested disposition: consider a mechanism-neutral minimum human-oversight event profile and a negative conformance annex spanning prEN 18229-1 and prEN 18229-3. EMILIA's formats and vectors are offered only as executable input showing that the proposed requirements can be implemented and independently tested.